

AuthShield 360 v2 — تقرير المشروع

منصة دفاع هوية تكيّفي (Risk-Based Authentication) بإصدار المؤسسي/التعليمي

المشروع	AuthShield 360 — منصة مصادقة تكيّفية بدرجة 0-100 ومراقبة SOC حيّة
الإصدار	v2 (Real-Time Enterprise Edition)
المرجع	«TechWiz 7 SRS «Ethical Cyber Horizons (مستخلص: reference/srs-extracted.txt/..)
البيئة	Node ≥ 24 (node:sqlite مضمّن) · SSE · Vanilla SPA · Nodemailer/Ethereal · SQLite · Express
تاريخ التقرير	٢٦-٠٩-٢٠٢٦

(١) نظرة عامة

AuthShield 360 نظام مصادقة محلي بالكامل (لا إنترنت ولا قواعد خارجية) يطبّق منهجية المصادقة حسب المخاطر: كل محاولة دخول تُقيّم فورًا بمحرك خطر تكيّفي من 0 إلى 100 مع أسباب مفسّرة، ثم يُتخذ قرار حسب النطاق:

- **LOW (0-30):** دخول مباشر (سيناريو 1) أو خطوة OTP عند الطلب (سيناريو 2/3).
- **MEDIUM (31-69):** موافقة عبر الجهاز الموثوق (Cross-Device Approval) بأسلوب Apple/Google، أو بديل البريد الإلكتروني + OTP.
- **HIGH (70-100):** قفل فوري للحساب + تنبيه للمشرف.

الإصدار v2 أضاف أربعة مكوّنات رئيسية: بوابة مدرسية بسياسات RBAC صارمة، استرداد الحساب وإعادة ضبط MFA، لوحة التحقيق الرقمي (Forensics) لإعادة بناء الخط الزمني للأحداث، ولوحة أداء مقارنة سيناريوهات المصادقة بزمان حقيقي `elapsed_ms`.

(٢) ما الذي أنجز في v2

المكوّن	التفاصيل
إعادة هيكلة الكود	فصل كامل: (SPA) / <code>frontend/</code> معزول عن <code>/backend/</code> (خدمات + مسارات). هجرة قاعدة بيانات إصدارية <code>m001</code> (مدرسة/استرداد/تحقيق) + <code>m002</code> (فهارس) + عمود <code>elapsed_ms / scenario</code> في سجل الأحداث.
واجهة جديدة كليًا	SPA بوحدات (api/soc/user/portal/forensics/app) — شريط تطبيق علوي، تبويبات، كروت بوابة، لوحة تحقيق، مصفوفة صلاحيات، تصميم متجاوب، Toasts.
البوابة المدرسية RBAC +	وحدات (مقررات/درجات/تكاليفات/حضور/قوائم صفية/دليل مستخدمين) لكل دور: STUDENT / TEACHER / ADMINISTRATOR عبر <code>portalGate(roles)</code> مع مصفوفة 3×8 تُعرض للمشرف.
استرداد الحساب / إعادة ضبط MFA	<code>request → reset → validate</code> : رمز تحقق 6 خانات، تدوير TOTP + كلمة مرور، 10 رموز استرداد أحادية الاستخدام، تسجيل كل خطوة في سجل الأحداث.
التحقيق الرقمي	إعادة بناء خط زمني مرتب للأحداث عبر المستخدم/IP/الجهاز/النتيجة، فتح قضية تلتقط الأدلة تلقائيًا، تصدير تقرير أدلة Markdown ، بحث، إغلاق/حذف.

العامل	الوزن	ملاحظة
F_IMPOSSIBLE_TRAVEL (< 1,000 كم/دقيقة)	40+	GEO_TABLE عبر Haversine
F_BLACKLISTED_IP	45+	ضمن القائمة السوداء
تجميع مع فهرسة	100-0	levels: LOW/MEDIUM/HIGH

- **ثبات/تشفير:** كلمات المرور `SHA-256 + pepper` (مستوى تجريبي)، رموز الجلسات عشوائية، بيانات TOTP/RFC 6238 بنافذة 30 ثانية + كشف انتهاء الصلاحية، كوكبي الوثوق AES-256-GCM لمدة سنة قابلة للإلغاء.
- **مكافحة قفل ذكي:** 3 محاولات كلمة مرور خاطئة ⇒ قفل بلا كشف وجود الحساب (تأجيل فشل غير معروف الهوية)، محاولات OTP لا تقفل الحساب.
- **RBAC:** سيناريو 3 لطلاب يُحوّل إلى `HIGH_RISK_BLOCK (UNAUTHORIZED_ROUTE)`، وبوابة المدرسة بواجه `portalGate(roles)` على المخدم (403).

٥) بوابة المدرسة ومصفوفة الصلاحيات

الوحدة	STUDENT	TEACHER	ADMINISTRATOR
المقررات Courses	✓	✓	✓
الدرجات/النتائج	✓ خاصته	✓ مقرراته	✓ الكل
التكليفات	✓ المُسجّل بها	✓ مقرراته	✓ الكل
الحضور	✓	✓	✓
القوائم الصفية	✗ 403	✓ مقرراته	✓ الكل
دليل المستخدمين	✗ 403	✗ 403	✓
مراقبة SOC	✗ 403	✗ 403	✓
التحقيقات الجنائية	✗ 403	✗ 403	✓

ملف كامل: `User_and_Role_Access_Matrix.md`.

٦) الاسترداد والتحقيق والأداء

استرداد الحساب / إعادة ضبط MFA

`POST /api/recovery/request` (6 identifier → verifyCode خانات) → `POST /api/recovery/reset` (تدوير TOTP + تغيير كلمة المرور + إصدار 10 رموز استرداد أحادية الاستخدام) → `POST /api/recovery/validate` (استهلاك الرمز مرة واحدة). يُسجّل `RECOVERY_REQUEST/RESET/CODE_VALID` في سجل الأحداث والتنبيهات.

التحقيق الرقمي

`api/forensics/{summary,entities,timeline,cases}/` — الخط الزمني يعيد ربط الأحداث (رمز مرجعي `ref` + نوع الحدث + زمن) عبر نطاق المستخدم/IP/الجهاز/النتيجة؛ القضية تلتقط الأدلة تلقائيًا؛ التصدير بصيغة **Markdown** يعطي تقرير أدلة جاهزًا للأرشفة.

الأداء (Benchmark)

api/benchmark/ يقرأ elapsed_ms الحقيقي من audit_trail ويقارن السيناريوهات الثلاثة: عدد المحاولات، متوسط زمن الدخول، عدّادات النجاح/الفشل/الحجب — مؤشر لإثبات فعالية الحل.

٧ إستراتيجية الاختبار والأدلة

المجموعة	الأداة	النتيجة	يغطّي
Smoke	scripts/smoke.js	17/17	محرك الخطر (أوزان/نطاقات/أسباب)، S1/S2/S3، إقفال، تسجيل→تحقق→جهاز موثوق
E2E شامل	scripts/e2e-all.js	77/77	كل السيناريوهات + الموافقة عبر الجهاز + القوائم + الهجمات SSE + A/B/C + بوابة RBAC (3 أدوار) + استرداد + تحقيق + أداء
UI	scripts/ui-smoke.js	28/28	تجربة المتصفح: دخول، تبويبات، بوابة، مصفوفة، تحقيق، أداء، مركز الأمان، خروج
NFR	scripts/restart-check.js	18/18	بقاء المستخدمين/الجلسات/الأجهزة/سجل الأحداث/القضايا/المحاكاة بعد إعادة تشغيل العملية

المجموع: 140 فحصًا أخضرًا على قاعدة نظيفة (start → reset-db → kill → تشغيل المجموعة).

ملاحظة مهمة من سجل التطوير: عند توليد قاعدة نظيفة تكون كل الأجهزة/الشبكات «غير موثوقة»، فيسلك اختبار E2E مسار سلسلة الموافقة (approve→finalize) تلقائيًا — وهو أكثر تحديًا وصدقًا. كما اكتُشف وأُصلح خلل حقيقي: courseRosters تجاه ADMIN مرر null لاستعلام بلا معاملات → «column index out of range» (أصبح portals يعمل للمشرف).

٨ حسابات تجريبية

المستخدم	كلمة المرور	الدور
admin	Admin@123	ADMINISTRATOR (SOC/بوابة/تحقيق/أداء)
student1 · student2	Student@123	STUDENT (مركز أمان + بوابة)
teacher1 · teacher2	Teacher@123	TEACHER (بوابة + قوائم صفية)

لوحة DEMO في شاشة الدخول تعرض OTP الحي لكل حساب (تحدث كل 30 ثانية).

٩ التسليمات

الوصف	الملف
هذا التقرير (عربي/إنجليزي)	Technical_Report_AR.md · Technical_Report_EN.md
مصفوفة الأدوار 3×8	User_and_Role_Access_Matrix.md
مصفوفة اختبارات الأمان القابلة للتكرار + الأدلة	Identity_Security_Test_Matrix.md / .json
سير العمل التقني الكامل	reference/WORKFLOW.md/..

الوصف	الملف
دليل بالعربية لغير المختصين	docs/01-دليل_التشغيل_والاستخدام.md
العرض التقديمي بالعربية	presentation/index.html
فيديو تسجيل حي لكل المراحل والميزات	demo.mp4
مجموعة اختبارات آلية كاملة (140 فحصًا)	*/scripts

١٠ ملاحظات وإخلاء مسؤولية

منصة تعليمية/عرضية — ليست بديلًا عن موقّر هوية معتمد (Auth0/Keycloak/Entra ID) في بيئة إنتاج. كلمات المرور تجريبية (SHA-256+pepper)؛ يُستبدل بـ argon2/scrypt في الإنتاج.